

Act of Kindness — Donation Portal

Tech Stack, Architecture & Costs — Simplified EC2 / RDS / S3 Build

1. Tech Stack

Layer	Technology	Notes
Frontend	React	Served from the same EC2 instance via Nginx
Backend / API	Node.js + Express	Runs directly on EC2 via PM2 / systemd
Database	PostgreSQL (AWS RDS)	Single-AZ for this budget tier
Reverse proxy / TLS	Nginx + Let's Encrypt (Certbot)	Replaces ALB + ACM
Compute	AWS EC2 (t3.micro)	Single instance — no ECS/Fargate
File storage	AWS S3	Receipts / payment proof uploads only
Payments	Stripe, PayPal	Online donation processing
Bank sync	GoCardless Bank Account Data / TrueLayer	Barclays feed — UK-priced alternative to Plaid
Test environment	KVM VM + Docker Compose	Local staging before AWS deploy

2. Architecture Overview

Restricted to EC2, RDS, and S3 only. One EC2 instance now does the job previously split across ECS Fargate, the Application Load Balancer, NAT Gateway, and CloudFront.

Component	Runs on	Purpose
Nginx	EC2 instance	TLS termination (via Let's Encrypt) and reverse proxy — replaces ALB + ACM
React build	EC2 instance	Served directly by Nginx — replaces S3 static hosting + CloudFront
Express API	EC2 instance	Runs as a persistent process (PM2/systemd) — replaces ECS Fargate
PostgreSQL	RDS (private subnet)	Single-AZ; only reachable from the EC2 security group
S3 bucket	AWS S3	Receipts / payment-proof storage only — not public-facing

3. What Was Removed (vs. the ECS/ALB/CloudFront design)

Removed	Replaced by	What is lost
ECS Fargate	Node/Express run directly on EC2	AWS no longer manages server patching for you
ALB	Nginx on the EC2 instance	No traffic spreading across multiple instances
AWS WAF	Nginx rate-limiting + app validation only	No managed protection against SQLi / bot attacks
NAT Gateway	EC2 sits in a public subnet directly	Public/private subnet isolation is reduced
CloudFront	Frontend served from EC2 via Nginx	No CDN caching or edge HTTPS
ACM	Certbot / Let's Encrypt on the instance	Renewal is self-managed, not automatic
Secrets Manager	.env file on the instance	Credentials are not encrypted at rest by AWS
GuardDuty / CloudTrail	Basic CloudWatch only	No account-wide threat detection or audit trail

4. Cost Breakdown

AWS's Free Tier changed on 15 July 2025. New accounts get a \$100–\$200 credit that expires after 6 months, not a guaranteed 12 months of free EC2/RDS. Confirm the AWS account's creation date before quoting a \$0 starting cost to the client.

Component	Configuration	Est. monthly cost
EC2	t3.micro, 1 instance	~\$7.50
EBS storage	20GB gp3	~\$1.60
RDS PostgreSQL	db.t4g.micro, Single-AZ	~\$12.00
RDS storage	20GB gp3	~\$2.30
S3	Receipts / proof uploads	~\$0–1.00 (5GB always free)
Total (pay-as-you-go)		~\$23–25/month

To bring this closer to a \$20/month target: stop the EC2 instance outside working hours (billed hourly, not flat-rate), keep RDS Single-AZ, and stay on the smallest instance sizes above. This budget suits a development/testing phase only — no Multi-AZ failover and no load-balanced redundancy.

5. Third-Party Integrations

Service	Purpose	Used in
Stripe	Online card payments (1.2–1.5% + 20p, UK charity rate)	Website donation flow
PayPal	Alternate online payment method (1.4% + 20p, UK charity rate)	Website donation flow

Service	Purpose	Used in
GoCardless Bank Account Data / TrueLayer	Read-only sync of Barclays transactions	Bank feed reconciliation

6. Security Notes for This Simplified Build

- RDS security group must only accept connections from the EC2 instance's security group, never 0.0.0.0/0
- Webhook signature verification (Stripe, PayPal, bank sync) is still required — this doesn't change with the simpler infrastructure
- The .env file replacing Secrets Manager must never be committed to git and should have restricted file permissions on the instance
- Role-based access control stays enforced server-side in the Express app, regardless of hosting choice
- Audit logging on financial record changes is an application-level concern, unaffected by this infrastructure change
- OS-level patching on the EC2 instance is now the team's responsibility, not AWS's — schedule regular updates

This reflects the budget-restricted architecture (EC2 / RDS / S3 only). See the earlier full AWS reference document for the resilient production-grade version (ECS Fargate, ALB, WAF, CloudFront).